

WAF 분석 보고서

저장된 자동 분석 결과를 정리한 보고서입니다. 보고서 조회로 새 분석이 실행되지는 않습니다.

자동 분석 결과 · 최종 판단은 분석가가 검토합니다. 공격 시도와 실제 피해 발생은 구분합니다.

01 판정 요약

판정	판단 보류 (inconclusive)
위협 심각도	미확정
보류 구분	보류 이유
입력 잘림	없음 (false)

등록 문서에는 여러 공격 예제가 포함되어 있고, 교육 자료임을 나타내는 내용도 있습니다. 문서가 실행되지 않는 텍스트로만 표시되는지 확인하기 전에는 정탐·오탐을 확정하기 어렵습니다. 근거 개수는 판정 점수가 아닙니다.

아래는 자동 분석 중 작성된 해석입니다. 공격·정상으로 단정하는 문장이 있어도 확정된 결론으로 사용하지 마세요.

판단이 필요한 부분

판단할 내용	교육 예제가 저장·출력 과정에서 실행될 수 있는가
아직 확인되지 않은 조건	문서 본문을 실행부와 분리하고 텍스트로 표시하는지 여부
관련 근거	1 · 2 · 5

02 분석 개요

처리 상태	완료 (completed)	회사명	시안용 가상 조직
출발 IP	192.0.2.10	출발 포트	51432
목적 IP	198.51.100.20	목적 포트	443
WAF 벤더	시안용 WAF	WAF Action	Deny (D)
이벤트명	보안 교육 문서 등록 요청 탐지	입력 시그니처	Multiple attack examples

WAF Action은 관측값이며 AI 판정의 정답이나 공격 성공 여부가 아닙니다.

03 세부 분석

검토한 유형	문서 내 공격 구문
분석 위치	요청 본문
분석 내용	SQL, HTML, 경로 이동 예제가 한 문서에 들어 있습니다. 각 예제의 문법과 문서 등록이라는 사용 맥락을 함께 살펴야 합니다.
예상 영향	본문이 명령어나 HTML로 실행되는 경우 영향을 줄 수 있습니다. 단순한 텍스트 보관이면 같은 문구라도 실행 효과는 없습니다.

탐지 내용과 요청의 연관성

관계	부분 일치 (partial)
설명	공격 문법은 존재하지만 교육 예제인지 실제 실행 입력인지 추가 확인이 필요합니다.

04 판정 근거

로그에서 확인한 발체와 그에 대한 해석입니다. 근거 개수로 판정을 결정하지 않습니다.

정탐 근거

근거 1

위치: 요청 본문

로그 발체:

```
example_sql: ' OR 1=1 --
```

판단 이유:

SQL 조건 우회 문법이 포함되어 있습니다. 데이터베이스 실행부에 전달되는지 여부는 별도 확인이 필요합니다.

근거 2

위치: 요청 본문

로그 발체:

```
example_html: <img src=x onerror=previewOnly()>
```

판단 이유:

이벤트 속성으로 함수를 호출하는 HTML 예제가 있습니다. HTML 해석 여부가 중요합니다.

근거 3

위치: 요청 본문

로그 발체:

```
example_path: ../../private/preview.txt
```

판단 이유:

상위 경로 이동 표현이 있습니다. 실제 파일 경로로 사용되는지 확인되지 않았습니다.

근거 4

위치: 요청 본문

로그 발췌:

```
example_cmd: ; printf preview-only
```

판단 이유:

명령 구분자 예제가 들어 있습니다. 서버에서 셸 명령으로 실행되었다는 뜻은 아닙니다.

오탐 근거

근거 5

위치: 요청 경로

로그 발췌:

```
/training/articles
```

판단 이유:

교육 문서 등록 경로로 보여 문서 예제 제출이라는 정상 사용 맥락을 뒷받침합니다.

근거 6

위치: 요청 본문

로그 발췌:

```
title: 입력 검증 교육 예제
```

판단 이유:

문서 제목이 입력 검증 교육임을 명시합니다. 제목은 사용자가 정할 수 있으므로 이것만으로 정상 판정을 확정하지 않습니다.

근거 7

위치: 요청 본문

로그 발췌:

```
notice: 실행하지 말고 문자열로 표시하세요.
```

판단 이유:

본문에 텍스트 예제로 다루라는 설명이 있습니다. 실제 출력 처리와 일치하는지 확인해야 합니다.

참고 내용

근거 8

위치: HTTP 헤더 · content-type

로그 발췌:

```
application/json
```

판단 이유:

클라이언트의 전송 형식입니다. 문서가 이후 어떤 형태로 출력되는지는 알려주지 않습니다.

근거 9

위치: HTTP 메서드

로그 발췌:

POST

판단 이유:

본문을 전송한 메서드입니다. 메서드 자체는 공격 여부를 결정하지 않습니다.

근거 10

위치: WAF 조치

로그 발췌:

D

판단 이유:

WAF가 차단했다는 관측만 확인됩니다. 공격 성공 증거로 사용하지 않습니다.

05 인코딩·난독화 문자열

아직 원문 기반 디코딩 결과를 조회하지 않았습니다. HTTP 원문 탭을 열어 조회한 뒤 보고서에 원문과 변환 결과를 포함할 수 있습니다. 보고서가 원문을 자동 조회하지는 않습니다.

06 소요 시간

접수 시각	2026-09-15T03:00:00Z	최초 처리 시작	2026-09-15T03:00:01Z
종료 시각	2026-09-15T03:00:06Z	전체 경과 시간	6000 ms
큐 대기 시간	1000 ms	처리 경과 시간	5000 ms

시간은 API가 제공한 조회 시점의 값입니다. 진행 중인 분석은 그 시점까지의 경과이며, 처리 시간에는 재시도와 작업 복구 대기가 포함될 수 있습니다. 단계 시간의 합계나 CPU 사용시간이 아닙니다.

07 추가 확인 사항

원문과 기록된 확인 항목을 검토하세요. 추가 자료는 판정을 가르는 경우에만 확인하면 됩니다.

안내된 자료를 시스템이 이미 조회했다는 뜻은 아닙니다.

확인 1

확인 위치	교육 문서 저장·조회 기능
확인할 내용	본문이 SQL·셸 명령에 직접 결합되지 않고 HTML 출력 시 이스케이프되는지 확인해 주세요.
확인 목적	교육 예제 문자열과 실행 가능한 공격 입력을 구분하기 위해 필요합니다.